

File No.: EXP202315244

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on 25/09/2023. The complaint is directed against the DEPARTMENT OF EDUCATION AND EMPLOYMENT of the GOVERNMENT OF EXTREMADURA, with NIF S0611001I (hereinafter, the respondent). The reasons for the complaint are as follows: the complainant and their spouse applied in June for assistance for the purchase of textbooks and school supplies; the entity responsible for processing the resolution of the aforementioned assistance is C.E.I.P Nuestra Señora de la Soledad (the respondent); on 04/09/2023, the respondent sent a message to the parents of students enrolled in the school with an attached Excel file, informing them that the file contained the resolution of the requested assistance; the complainant states that upon checking the file, they observed that in the tab "3rd Course Non-Scholarship Income Order," the economic data of the families of students who had not received scholarships appeared; according to the complainant, data protection regulations have been violated by revealing the income level of their family unit.

Along with the complaint, copies of the ID cards and Family Book are provided; the application for assistance addressed to the Department along with the attached documentation.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) by electronic notification, was not collected by the responsible party within the availability period, being understood as rejected in accordance with the provisions of Article 43.2 of the LPACAP on 30/10/2023, as stated in the certificate in the file.

Although the notification was validly carried out by electronic means, with the procedure being considered completed in accordance with the provisions of Article 41.5 of the LPACAP, an informational copy was sent by postal mail, which was duly notified on 21/11/2023. In this notification, the obligation to communicate electronically with the Administration was reminded, and information was provided on the means of access to such notifications, reiterating that, henceforth, notifications would be made exclusively by electronic means.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

THIRD: On 25/12/2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On 12/02/2024, the respondent confirmed the facts presented by the complainant, acknowledging the error caused by sending an Excel file to the families applying for assistance, which allowed access to the data of the students and the income level of each.

FIFTH: On 10/04/2024, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent for the alleged violations of Articles 5.1.f) and 32.1 of the GDPR, classified respectively in Articles 83.5.a) and 83.4.a) of the aforementioned GDPR and sanctioned in accordance with the provisions of Article 77 of the LOPDGDD.

SIXTH: After the notification of the initiation agreement, the respondent submitted a written statement on 10/05/2024, stating the following: that they reiterated the information provided in response to the

request made by the AEPD; their disagreement with what was stated in the fourth fact of the initiation agreement; that regarding the violations, Article 5.1.f) was not breached, as the data was not published but the message was directed exclusively to the applicants, and that Article 32.1 of the GDPR was also not breached, thus the case should be archived.

SEVENTH: On 21/05/2024, a period for the practice of evidence was initiated, agreeing to the following:

- To consider the complaint filed by the complainant and its documentation reproduced for evidentiary purposes, along with the documents obtained and generated that are part of the file.
- To consider the allegations regarding the initiation of the referenced sanctioning procedure, presented by the respondent and the documentation provided, reproduced for evidentiary purposes.

EIGHTH: On 31/01/2025, a Proposal for Resolution was issued stating that the Director of the AEPD declared that the respondent had infringed the provisions of Articles 5.1.f) and 32.1 of the GDPR, classified in Articles 83.5.a) and 83.4.a) of the GDPR.

After notifying the Proposal on 05/02/2025, the respondent has not submitted any written allegations. From the actions taken in this procedure, the following has been established:

PROVEN FACTS

FIRST. On 25/09/2023, a written statement from the complainant was received by the Spanish Agency for Data Protection, in which they state that together with their spouse, they applied for assistance for the purchase of textbooks and school supplies; the entity responsible for processing the resolution is C.E.I.P Nuestra Señora de la Soledad; the respondent sent a message to the parents of the children enrolled in the center.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

3/11

a message with an attached Excel file, containing the resolution of the requested aid and that upon examining the file in the tab "3rd Course Non-Scholarship Income Order" the economic data of the family units of the students who had not been awarded scholarships appeared; according to the claimant, the data protection regulations have been violated by revealing the income level of their family unit.

SECOND. Copies of the DNIs of the claimant and their spouse, as well as the Family Book, have been submitted.

THIRD. Along with the Report Card from C.E.I.P Nuestra Señora de la Soledad, the Application from families for the acquisition of textbooks and school materials for the 2023/24 academic year directed to the Ministry of Education has been submitted, along with the necessary documentation attached to it.

FOURTH. There is a message in which the file containing the lists of Scholarship and Non-Scholarship recipients is forwarded.

FIFTH. In the Non-Scholarship list for 3rd grade, the minor child of the claimant appears with the economic data of the family unit in the adjacent column.

SIXTH. A technical report has been submitted regarding the causes that led to the incident and the measures adopted. In its Fourth heading, it is noted that a consultation was made to CEIP Ntra. Sra. de la Soledad de Aceuchal (Badajoz), by the director of the educational center, who sent a report dated 21/11/2023, with the following content:

At the beginning of the 23/24 academic year, our center distributes scholarship books to students who are granted free access, and if the center has surplus books in our school book bank, we also distribute them to students who, although not granted free access, we want to benefit from them. Thus, the secretary of the center prepared a list of these students to organize them by the economic income of their families in an Excel document where other documents were stored that she was working on.

To make this list known, we mistakenly sent this list to the families, making public the names of the students along with each one's income, thinking it was another document.

I acknowledge that it was a human error that could have happened to anyone, and we understand the

feelings of these families.

At no time did we intend to bypass the data protection law of these families with the publication of this list and their incomes" (the underlining corresponds to the AEPD).

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

For its part, Article 90.2 of the LPACAP states that: "in the resolution, facts different from those determined during the procedure cannot be accepted, regardless of their different legal valuation. However, when the competent authority for resolution considers that the infringement or sanction is of greater severity than that determined in the proposed resolution, the accused will be notified to provide any allegations they deem appropriate within a period of fifteen days."

II

Obligation breached: Article 5.1.f) of the GDPR

The reported facts materialize in the sending by the defendant of a message through the Rayuela platform, attaching a file in Excel format that contained the resolution of the requested aid, listing non-scholarship students for 3rd grade along with the economic data of their family units, including that of the claimant, which violates the regulations on personal data protection.

The defendant processes the data in its capacity as the data controller, as it is the one who determines the purposes and means related to it, by virtue of Article 4.7 of the GDPR.

Moreover, the data controller must also implement the technical and organizational measures that ensure the security of personal data when carrying out the processing. And be able to demonstrate compliance with the GDPR and the LOPDGDD.

Firstly, the processing carried out could constitute a breach of Article 5, Principles relating to processing, of the GDPR which states that:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality').

(...)"

5/11

From the documentation in the file, it is concluded that the respondent violated Article 5 of the GDPR, principles related to processing, by enabling access to personal data, including that of the claimant, to unauthorized third parties, through the sending of a message to the parents of students at the center that contained a file in Excel format which included the resolution of aid requested for the acquisition of textbooks and school materials. The document also contained data corresponding to the income level of the families of the students listed.

The claimant indicated in their submission that the provided file contained the economic data of the family units of students who had not been granted scholarships, considering that this violates the regulations on data protection.

In this regard, the aforementioned Article 5.1(f) of the GDPR provides that personal data shall be processed in such a way as to ensure its security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of

appropriate technical or organizational measures.

On the other hand, Recital 39 of the GDPR, in clear reference to the principle set out in Article 5.1(f) of the GDPR, states that: "Personal data must be processed in a manner that ensures appropriate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used for processing."

The loss of confidentiality poses a risk that may lead to material or immaterial damages for individuals (Recital 85 of the GDPR). In this sense, Recital 75 of the GDPR establishes that: "Risks to the rights and freedoms of individuals, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to discrimination issues, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where individuals are deprived of their rights and freedoms or are prevented from exercising control over their personal data; ..."

Therefore, access by unauthorized third parties to personal data means that such data may be used for unknown, even fraudulent, purposes, resulting in a total and absolute loss of control over them.

In this same sense, Article 28 of the LOPDGDD, regarding the obligations of the data controller within the framework of Articles 24 and 25 of the GDPR to ensure and demonstrate that the processing is in compliance with the GDPR concerning various risks, provides that,

"(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/11

2. For the adoption of the measures referred to in the previous section, the data controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to those affected. ...".

In this case, the printout of the list of non-scholarship students in 3rd grade has been submitted, which includes the child of the claimant and contains a column with the income level of the students' families. Despite the fact that the respondent has claimed that the reported facts materialize in the sending via the Rayuela platform of a message with an attached file addressed exclusively to the interested parties or applicants for scholarships, it does not consider that sensitive data has been affected.

Sensitive data or data subject to special protection are those that refer to the most intimate sphere of their holder, or whose improper use may give rise to discrimination or may entail a serious risk to them. In any case, the respondent has confirmed the facts in a document dated 12/02/2024 and has stated that upon consulting CEIP Ntra. Sra. de la Soledad, it maintains that:

(...) At the beginning of the academic year 23/24, our center distributes scholarship books to students who are granted free access, and if the center has surplus books in our school book bank, it also distributes them to students who, although not granted free access, we want to benefit from them.

Thus, the secretary of the center prepared a list of these students to organize them by the income level of their families in an Excel document where she had saved other documents she was working on.

To make this list known, we mistakenly sent this list to the families, making public the names of the students along with each one's income, thinking it was another document.

I acknowledge that it was a human error that could have happened to anyone, and we understand the feelings of these families.

At no time did we intend to bypass the data protection law of these families with the publication of this list and their incomes.

In light of these statements made by the director of the CEIP, the respondent has indicated that “the educational center acted in accordance with the terms of the call for applications, although it sent a message via the Rayuela platform with an attached Excel file to all the parents of the students enrolled in the center, and in ordering the list of students by income level, the column with the income level was mistakenly included, a circumstance that should not have been included in any case.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/11

In accordance with the above, it is considered that the respondent has violated the principle of integrity and confidentiality of the data, a principle enshrined in Article 5.1.f) of the GDPR, an infringement classified in Article 83.5.a) of the GDPR.

III

Classification of the infringement of Article 5.1.f) of the GDPR

Article 83.5 a) of the GDPR considers that the infringement of “the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9” is subject to sanction.

For its part, the LOPDGDD in its Article 71, Infringements, states that:

“Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

Also, the LOPDGDD, for the purposes of prescription, in its Article 72 indicates:

“Very serious infringements:

1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years: infringements that constitute a substantial violation of the articles mentioned therein, and in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)”

IV

Article 32.1 of the GDPR: security of processing

The respondent is also attributed the possible infringement of Article 32 of the GDPR “Security of processing,” which establishes that:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/11

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the data processing, especially as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the

unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as a factor to demonstrate compliance with the requirements established in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law. Upon reviewing the documentation in the administrative file, it is evident that all the technical and organizational security measures whose absence has been proven directly enabled the personal data breach, without there being a violation, in this specific case, of Article 32 of the GDPR, as the absence of other independent technical and organizational security measures unrelated to the personal data breach has not been substantiated.

V

Applicable regime to the party being claimed

The LOPDGDD in its Article 77, Applicable regime to certain categories of controllers or processors, establishes the following:

“1. The regime established in this article shall apply to the processing for which they are responsible or processors:

(...)

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.

(...)

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed, except for that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.

The resolution shall be notified to the controller or processor, to the body to which they are hierarchically dependent, where appropriate, and to the affected parties who had the status of interested parties, where appropriate.

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the infringements are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is substantiated, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order publication in the Official State Bulletin or the corresponding autonomous bulletin.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions taken and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.

6. When the competent authority is the Spanish Agency for Data Protection, it shall publish on its website, with due separation, the resolutions related to the entities in paragraph 1 of this article, with express indication of the identity of the controller or processor who has committed the infringement. When the competence corresponds to an autonomous data protection authority, the publicity of these resolutions shall be subject to what its specific regulations provide.”

In the case examined, the present sanctioning procedure is based on the fact that the party being claimed, as stated in the facts, has violated the regulations regarding the protection of personal data, particularly the principle of integrity and confidentiality of the data.

As noted, in accordance with the evidence available, such conduct constitutes an infringement by the

party being claimed of the provisions of Article 5.1.f) of the GDPR.

It should be noted that the GDPR, without prejudice to what is established in its Article 83, contemplates in its Article 77 the possibility of declaring the infringement and, furthermore, establishing the measures that should be taken to correct the data processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/11

personal that do not comply with their provisions, when the responsible parties or agents listed in section 1 commit any of the infractions referred to in articles 72 to 74 of this organic law, as occurs in the present case.

However, regarding the measures, in its allegations, the responding party has indicated that "...in addition to the communications at the beginning of each academic year, an initiative has been launched in collaboration with the General Secretariat of Digital Transformation and Cybersecurity of the Ministry of Economic Affairs, Employment, and Digital Transformation to train and raise awareness regarding data protection among staff from all educational centers in the Autonomous Community, ensuring that at least one person from the management team of the centers attends," thus trying to avoid incidents like the one that occurred.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

The Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that the MINISTRY OF EDUCATION AND EMPLOYMENT of the JUNTA DE EXTREMADURA, with NIF S0611001I, has infringed the provisions of article 5.1.f) of the GDPR, classified under article 83.5 a) of the GDPR.

SECOND: TO ARCHIVE the MINISTRY OF EDUCATION AND EMPLOYMENT of the JUNTA DE EXTREMADURA with NIF S0611001I, for the infringement of article 32 of the GDPR, classified under article 83.4.a) of the GDPR.

THIRD: TO NOTIFY this resolution to the MINISTRY OF EDUCATION AND EMPLOYMENT of the JUNTA DE EXTREMADURA.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of article 77.5 of the LOPDGDD.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

Lorenzo Cotino Hueso
President of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/11